

Relatório do trabalho de grupo

Plano de segurança inicial para serviço web publicado

Curso: Linux e Segurança na Cloud | Skodji Digital — Sessão 4, Tópico 4

1. Identificação do grupo

Grupo: Grupo 3

Elementos: Anderson Mestre, Sandra Borges, Anete Oliveira, Cely Neves

Papéis assumidos: Anderson Mestre — caracterização do serviço, aplicação e documentação das regras de firewall e das medidas de hardening, e redação do relatório(...).

2. Serviço analisado

Cenário escolhido: Cenário Serviço A — HTML com Nginx.

O serviço analisado corresponde ao site referido no Tópico 3 — o pequeno site simples com HTML e CSS, definido, implementado e validado no relatório de grupo desse tópico servido pelo Nginx num Linux Ubuntu Server.

- Serviço: servidor web Nginx a servir um pequeno site simples com duas páginas (index.html, sobre.html) e uma folha de estilos (style.css).
- Porta / protocolo: TCP 80 (HTTP), com resposta HTTP/1.1 200 OK confirmada nas três URLs testadas. A porta 443 (HTTPS) foi bloqueada, por não ter sido configurado certificação TLS.
- Diretório de publicação: /var/www/html/topico-03/
- Componentes envolvidos: Linux Ubuntu Server, serviço Nginx, ficheiros estáticos (index.html, sobre.html, style.css), acesso SSH para administração remota via Bitvise Client. Foram ainda instalados Fail2ban, Lynis e Aide.
- Dependências principais: o sistema depende do Nginx, as ferramentas e medidas de segurança instaladas e as do sistema operativo.

3. Superfície de ataque

Elemento exposto	Risco	Necessário?	Medida proposta
SSH	Acesso remoto não autorizado; ataques de força bruta a passwords.	Sim, apesar não ter configurado uma porta específica de acesso mantendo o padrão.	Restringir por IP de confiança; preferir autenticação por chave; foi instalado Fail2ban para banir automaticamente IPs com atividade suspeita e restrições de acesso temporários.
HTTP	Tráfego não cifrado; interceção de dados em trânsito.	Sim, para manter o site público.	Manter aberto por agora; planear uma migração para HTTPS.
HTTPS	Não está configurado.	Não configurado atualmente e porta está bloqueada.	Posso configurar um certificado TLS numa fase seguinte.
Diretório web	Exposição de ficheiros e diretórios do sistema Linux desprotegidos.	Sim, necessário para servir o site.	Desativar autoindex para evitar exposição de arquivos de forma inadvertida para outros.

4. Regras de firewall propostas

- - Para o cenário as portas abertas para funcionamento do serviço web estático são a 22(SSH) e 80(HTTP).
- - Todas as outras portas que estão a ser usados para o cenário devem ficar fechadas inclusive a 443(HTTPS), 3036(MySQL).
- - SSH deve estar acessível somente aos administradores do sistema, técnicos qualificados e pessoas restritamente autorizadas.
- - HTTP para o acesso ao web deve permanecer aberto no caso do uso de serviços que precisem desse acesso.
- - O HTTPS não foi configurado para esse cenário.
- - A base de dados deve ficar acessível somente para os serviços, aplicativos ou sites que necessitem desse acesso para funcionamento.

Serviço	Porta	Decisão	Justificação
SSH	22	ALLOW IN	Necessário para administração remota via Bitwise; o risco é mitigado com Fail2ban e com a recomendação de autenticação por chave em vez de password
HTTP	80	ALLOW IN	É a porta pública através da qual o site é servido; deve ficar aberta para o serviço cumprir o seu objetivo
HTTPS	443	DENY IN	Regra aplicada explicitamente (sudo ufw deny 443/tcp); ainda não existe certificado TLS configurado no servidor
MySQL	3306	Por bloquear.	Por não ter sido usado uma base de dados neste cenário a porta não deve estar exposta.

5. Medidas de hardening inicial

Medidas iniciais aplicadas:

1. Manter os pacotes do sistema atualizados com por exemplo `sudo apt update && sudo apt upgrade -y`.
2. Rever as permissões em `/var/www/html/topico-03/`: dono `www-data`, permissões `755` em diretórios e `644` em ficheiros.
3. Desativar a listagem de diretório no Nginx, confirmada com `sudo nginx -t`.
4. Bloquear na firewall todas as portas que não sejam estritamente necessárias (443 bloqueadas).
5. Instalar e configurar Fail2ban, para banir automaticamente IPs com atividade suspeita de força bruta sobre o SSH.
6. Instalar ferramentas de detecção de intrusão e de auditoria do sistema como Aide e Lynis para identificar recomendações e alertas adicionais.

6. Plano de validação

Validação	Como fazer	Resultado esperado	Evidência
Estado da firewall	sudo ufw status verbose	22/tcp e 80/tcp em ALLOW IN; 443/tcp em DENY IN	Print do comando, guardado em evidencias/6.png
Serviço web acessível	curl -I http://192.168.4.107/topico-03/index.html e repetir nos outros	HTTP/1.1 200 OK nos três pedidos	Print do comando, guardado em evidencias/9.png
SSH disponível	ssh amestre@192.168.4.107 a partir de uma máquina autorizada	Ligação estabelecida com sucesso via Bitvise ou PowerShell sem bloqueio.	Print da sessão SSH ligada na pasta evidencias/
Portas desnecessárias fechadas	sudo ufw deny 443/tpc		Print da porta já desativada na pasta evidencias/6.png

7. Link do repositório GitHub

<https://github.com/andbasket15-a15y/linux-seguranca-cloud>

8. Conclusão

O serviço web publicado no Tópico 3 apresenta uma superfície de ataque relativamente reduzida, por não incluir base de dados nem processamento de código no servidor. A nível dos testes que faço e outras funções mantenho algumas portas adicionais, mas não influenciam os serviços e trabalhos propostos e seus objectivos. As regras de firewall foram efetivamente aplicadas com SSH e HTTP permitidos, HTTPS bloqueado, e as medidas de hardening foram reforçadas com a instalação de Fail2ban, Lynis e Aide, indo além do hardening mínimo pedido. Este trabalho dá continuidade direta ao relatório do trabalho de grupo do Tópico 3 e continua a ser sustentado pela atividade individual feita pelo Anderson Mestre e pelo site alocado nos serviços Nginx, onde todas as medidas aqui descritas foram efetivamente aplicadas e validadas no Linux Server numa VM administradas pelo mesmo.